LABORATUVAR 6 EAE MAKİNA — RULO SAC DOĞRULTMA, ROLL FORM VE BOY KESME HATTI

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad:	Grup:	Tarih: ..... / ..... / 2026

Senaryo: Saat **10:15**. Rulo sac doğrultma, roll form ve boy kesme hattının servis hesabına gece **03:00**'te tanınmayan bir konumdan girilmiş. PLC konfigürasyonu, servo sürme boy ayarları ve giyotin makas zamanlaması değişmiş olabilir; ışık perdesi parametreleri henüz doğrulanmadı. Makine şu an 6 mm çelik sac işliyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıttır**. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1	**10:15 — ilk 15 dk: Kimi ararsınız? İlk üç eyleminiz?** **Aranacaklar:** OT Siber Güvenlik / Olay Müdahale Sorumlusu (CSIRT), Fabrika Üretim Müdürü ve İSG Mühendisi. **İlk üç eylem:** (1) Hattaki çalışanların zarar görmemesi için makineyi kontrollü güvenli duruşa (Safe Stop / E-Stop) alarak 25 tonluk rulo açıcıyı, merdaneleri ve giyotin makası enerjisiz bırakırım. (2) PLC ve HMI'yı **kapatmadan/resetlemeden** uzak bakım modülünün internet (WAN) kablosunu fiziksel olarak çekerim. (3) Operatörleri makas ve merdane bölgesinden uzaklaştırıp panoyu emniyet şeridine alırım.
2	**İlk 2 saat: Emniyet güvende mi nasıl doğrularsınız? Hangi kanıt korunur? Hangi hesap kapatılır?** **Emniyet doğrulaması:** Safety PLC içindeki emniyet programının kontrol toplamını (Safety Checksum / CRC) fabrika çıkış doğrulama raporuyla karşılaştırırım; ışık perdesi ve kapı kilitlerini fiziksel olarak tetikleyerek servo STO ve hidrolik valf kesme tepkisini test ederim. **Korunan kanıt:** Uzak bakım modülü RAM/bellek dökümü, PLC tanı tamponu (diagnostic buffer), HMI reçete değişim logları ve mevcut PLC kodunun yedeği. **Kapatılan hesap:** Gece 03:00'te giriş yapılan `servis` hesabı ve varsayılan `admin/admin` hesabı derhal askıya alınır.
3	**24 saat — CRA erken uyarı: Hangi bilgi hazır olmalı?** Yetkili otoriteye sunulmak üzere; olayın aktif olarak istismar edilen bir siber müdahale olduğu şüphesi, etkilenen makine serisi ve PLC firmware sürümü, yetkisiz erişimin gerçekleştiği saat (03:00) ve fiziksel emniyet zincirinin (Safety PLC) etkilenip etkilenmediğine dair ön durum özeti hazır olmalıdır.
4	**72 saat — CRA bildirim: Kök neden, etki, önlem — kim ne yapıyor?** **Kök neden:** İnternete doğrudan açık bırakılan uzak bakım modülü ve paylaşılan zayıf servis parolası. **Etki:** Üretim PLC'sindeki servo sürme ve boy kesim parametrelerine yetkisiz erişim (Safety PLC izole olduğu için yaralanma önlendi). **Önlem & Görev:** Otomasyon ekibi temiz PLC yedeğini yükleyip duruş sürelerini doğrularken, ağ güvenliği ekibi doğrudan dış bağlantıyı iptal ederek iDMZ, VPN ve MFA mimarisini devreye alır.
5	**14 gün — son rapor: Hangi loglar/kayıtlar korunmuş olmalı?** Güvenlik duvarı ve VPN bağlantı logları, uzak bakım modülü oturum kayıtları, değiştirilen PLC kodu ile orijinal kod arasındaki karşılaştırma (diff) raporu, Safety PLC emniyet doğrulama (validation) test tutanakları, güncellenmiş Risk Kaydı ve düzeltici/önleyici faaliyet (DÖF) raporu korunmuş olmalıdır.

En sık hata: "Resetleyip devam edelim" — o düğme, uçucu bellek (RAM) üzerindeki kanıtı sonsuza dek siler. **Önce emniyet, hemen sonra kanıt.**

☑ Bu föyün çıktısı Incident Workflow → Evidence Pack EP 13 Incident Response başlığına oturur.